

****Supervision of Notification of Breach of Personal Data Security****

Date: 31-08-2023

Decision

Private Companies

No Criticism

Supervision / Self-initiated Case

Notification of Breach of Personal Data Security

The Danish Data Protection Agency has conducted 16 planned inspections focusing on municipalities' and banks' handling of breaches of personal data security. The Data Protection Agency found reason to express criticism in two cases.

Journal Number: 2021-41-0131.

Lån & Spar Bank A/S (hereinafter Lån & Spar Bank) was among the companies that the Data Protection Agency selected for supervision in the autumn of 2021 under the General Data Protection Regulation[1] and the Data Protection Act[2].

The Data Protection Agency's supervision was a written inspection that focused, among other things, on whether Lån & Spar Bank had implemented appropriate security measures in accordance with Article 32, paragraph 1 of the General Data Protection Regulation, with the aim of reducing the number of breaches of personal data security involving unauthorized disclosure of personal data, including confidential information, particularly in relation to financial information.

The supervision was announced to Lån & Spar Bank by letter dated November 24, 2021, and the bank was simultaneously requested to respond to a number of questions and to submit an example of an instruction to the bank's employees regarding the handling of personal data, including in connection with the transmission of information to, among others, citizens, authorities, etc.

The Data Protection Agency informed about the background for the supervision, noting that a review of the Agency's cases concerning notifications of breaches of personal data security revealed that Lån & Spar Bank had reported significantly more breaches of personal data security per employee in the financial institution than other financial institutions. The Data Protection Agency noted in this context that the higher number of notifications does not necessarily indicate that the bank complies with data protection regulations to a lesser extent than financial institutions that have significantly fewer notifications per employee.

By letter dated January 19, 2022, Lån & Spar Bank sent a statement in which the bank responded to the Data Protection Agency's questions. Lån & Spar Bank's response was also accompanied by examples of relevant instructions and guidelines, etc.

****Summary****

The Data Protection Agency initiated written inspections in the summer and autumn of 2021 regarding the handling of breaches of personal data security by eight larger municipalities and eight larger banks. The inspections were organized so that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the municipality's population and the number of employees in the bank, respectively.

"One of the new things that came with GDPR over five years ago was that data controllers, as a general rule, must report all breaches of personal data security to the Data Protection Agency within 72 hours, and they must internally document all breaches of personal data security, regardless of whether they need to be reported to the Data Protection Agency or not. Furthermore, there has been an increased focus on what companies and authorities need to consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, chief consultant at the Data Protection Agency, and continues: "This can, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some samples. The conclusion is broadly that the 16 selected municipalities and banks seem to have the right focus on complying with the rules."

****Group with the Most Reported Breaches****

For the group with the most reported breaches, the inspections focused, among other things, on whether the municipalities and banks had implemented appropriate security measures to reduce the

number of breaches of personal data security involving unauthorized disclosure of personal data in connection with the transmission of information to, among others, citizens, authorities, etc., including in relation to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not come to the knowledge of unauthorized persons. The data controller must, in this context, ensure that all employees in the organization are familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc.

Procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Data Protection Agency found on the basis of the present material that all data controllers had implemented appropriate security measures. In its assessment, the Data Protection Agency emphasized that:

Procedures, etc. had been developed and activities had been carried out to educate employees in data protection, including to ensure that they are aware that there is no accidental disclosure of personal data to the wrong parties.

recipient.

They have considered and continuously implemented both technical and organizational measures in response to past breaches of personal data security to avoid similar breaches. There is a strong focus on preventing the unintended disclosure of confidential information, which is supported by business processes, ongoing guidance, etc., as well as systemic measures, etc.

****Group with the Fewest Reported Breaches****

For the group with the fewest reported breaches, the inspections focused on whether the municipalities and banks report and document breaches of personal data security in accordance with the requirements of the General Data Protection Regulation (GDPR), including their processes for handling and recording breaches of personal data security.

The Data Protection Authority stated in these cases that it is the Authority's view that compliance with the rules stipulating that breaches of personal data security must, in principle, be reported to the Data Protection Authority within 72 hours entails that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this regard, the data controller must ensure that all employees in the organization are familiar with internal procedures for handling breaches of personal data security, and that relevant employees can identify, manage, and assess breaches of personal data security.

The Data Protection Authority found that all data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have implemented suitable training activities that can support compliance with the requirements of the GDPR regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are captured within the organization so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as to document the breaches, including, among other things, the reasons for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that it had not had the opportunity, as part of the inspection, to specifically assess whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training materials, including the content of, for example, ongoing awareness initiatives.

Furthermore, the Data Protection Authority stated that the rule requiring the data controller to document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security is complied with.

Therefore, data controllers should document their reasons for all significant decisions made as a result

of the breach. This applies particularly if the data controller, after assessing the breach, concludes that it does not need to be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

****Criticism in Two Cases****

As mentioned, there has been pronounced criticism in two of the cases – specifically regarding two municipalities that did not document all breaches of personal data security.

In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified during the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the registered security incidents since September 2019 constitute actual breaches of personal data security.

In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality identified in 2018.

The Data Protection Authority notes that the list of breaches – in addition to serving as documentation for the Data Protection Authority – should also be used by the data controller to gain an overview of what types of breaches typically occur in the organization, and based on this, to consider whether there is a need to implement new or supplementary measures to avoid or further reduce the risk of additional breaches. It is also evident from the received consultation responses that several data controllers actively use the lists for this purpose.

****1. Decision****

After reviewing the submitted material, the Data Protection Authority finds on the basis of the present information that Lån & Spar Bank has taken appropriate security measures in accordance with Article 32(1) of the General Data Protection Regulation, with a view to reducing the number of breaches of personal data security where unauthorized disclosure of personal data occurs, including confidential information, particularly in relation to financial information.

Below follows a detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

****2. Justification for the Data Protection Authority's Decision****

It is stated in Article 32(1) of the General Data Protection Regulation that the data controller must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risks.

risks associated with the data controller's processing of personal data.

Thus, the data controller has an obligation to identify the risks that its processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks.

It is the opinion of the Data Protection Authority that the requirement in Article 32 for appropriate security will generally entail that the data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not become known to unauthorized parties, and that the data controller, in this context, must ensure that all employees in the organization are adequately familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc., and that procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

Lån & Spar Bank, in its statement of January 19, 2022, has, among other things, submitted the bank's procedures for data breaches (Appendix 9) and TLS encryption (Appendix 10). The bank has also provided examples of measures regarding the handling of personal data aimed at employees, including in connection with the disclosure of information. Lån & Spar Bank has, in this context, mentioned a training presentation, a video on data protection, as well as examples of the company's awareness activities (Appendices 1-8).

Lån & Spar Bank has stated that the bank – in connection with considerations regarding the risk of unintentional disclosure of information, including confidential information – has been working for several years with a concept called "secure communication," which is divided into two areas of focus, namely the technical front and the organizational front.

Regarding the technical front, Lån & Spar Bank has reported a number of technical measures aimed at ensuring an appropriate level of security when communication occurs between the bank's employees and customers. For example, Lån & Spar Bank has stated that communication to and from the bank's customers occurs, among other ways, via online banking, which requires a login. The bank's employees can write and forward information to customers via an internal system called "SAMBA," whereby the information never leaves the bank's environment, which is accessed via a secure connection and using NemID/MitID. Lån & Spar Bank also uses encrypted emails and emails that require employee signatures to send and/or read.

Furthermore, Lån & Spar Bank has stated that customers can receive notifications via SMS or email when the bank has contacted the customer via online banking. The notifications only contain a message that the customer must log in to online banking to read what the bank has sent.

As part of the technical front in the "secure communication" concept, Lån & Spar Bank also uses a screening tool to scan data in emails before they leave Lån & Spar Bank. The tool can identify sensitive information, primarily CPR numbers. It can thus identify patterns in text or files that match a known type of sensitive information. Sending emails that contain CPR numbers both in the email text and/or in attached documents will be blocked so that they do not leave Lån & Spar's mail server. In situations where it is necessary to send an email with confidential information, this can only be done if it is sent to a recipient who has been whitelisted. It can also be done by sending encrypted emails. Some of the bank's departments send encrypted emails out of the bank, which must be opened/sent with employee signatures. This is most often to the police, municipalities, and the tax authority (SKAT).

Regarding the organizational front, Lån & Spar Bank has stated that the bank has implemented a number of organizational measures aimed at preventing data breaches that may arise in connection with communication between the bank's employees and customers.

Overall, Lån & Spar Bank has reported three organizational measures that wholly or partially relate to secure communication and the handling of data breaches: Ongoing awareness campaigns and training for employees on, among other things, cybersecurity, phishing, and safe use of IT equipment; the development of business processes and implementation of procedures in the event of breaches of personal data security; as well as news and guidelines for employees that either aim to guide and/or remind employees about data protection-related topics, such as verifying customer relationships.

In this context, Lån & Spar Bank has stated that employees undertake GDPR courses through the "Financial Sector's Educational Center," and that Lån & Spar Bank has held special seminars for selected departments where the majority of tasks involve processing personal data. Lån & Spar Bank has also stated that the bank requires new employees to complete data protection training, and that all employees must undergo a data protection test every other year.

Lån & Spar Bank has also stated that the bank has had an internal GDPR committee since 2018, which meets quarterly to ensure ongoing attention to data protection regulations, including discussing the bank's latest data breaches, as well as deciding on new mitigating activities/changes. Additionally, the bank sends out news to the entire organization that includes advice and guidance on how to best avoid data breaches. The news is prepared based on analyses of historical data breaches.

Finally, Lån & Spar Bank has stated that the bank continuously... has implemented technical and organizational security measures aimed at reducing the number of breaches of personal data security, where there has been an unintentional disclosure of personal data. Lån & Spar Bank has provided an example of this by stating that changes have been made to the bank's secure communication environment, so that the employee must actively choose whether a partner or spouse should also receive what is sent, and that changes in information about the partner

or spouse are synchronized across the bank's systems. Furthermore, the bank plans to introduce a security measure that makes it mandatory to check whether the employee has uploaded the correct document for the correct customer before the document is sent.

It is – notwithstanding that the Data Protection Agency has not had the opportunity to take a specific position on whether all relevant employees have completed the relevant training activities, etc., and that the agency is not aware of the full content of all guidance and training materials – based on the present basis the agency's assessment is that Lån & Spar Bank has taken appropriate security measures in accordance with the General Data Protection Regulation (GDPR) Article 32, paragraph 1, aimed at reducing the number of breaches of personal data security, where there is unauthorized disclosure of personal data, including confidential information, particularly in relation to financial information.

In its assessment, the Data Protection Agency has emphasized the information provided by Lån & Spar Bank, including that procedures, etc., have been developed and activities have been carried out to educate employees in data protection, including to ensure that they are aware that there is no unintentional disclosure of personal data to an incorrect recipient, that Lån & Spar Bank, including through the internal GDPR committee, has considered and continuously implemented both technical and organizational measures following past breaches of personal data security to avoid similar breaches, and that there is a strong focus on avoiding unintentional disclosure of confidential information, which is supported both through business processes, ongoing guidance, etc., and systematic measures that aim to create secure communication channels between the bank's employees and customers.

The Data Protection Agency can, upon a renewed review of the agency's cases regarding reports of breaches of personal data security, ascertain that since November 24, 2021, there has been a decrease in the number of reported breaches of personal data security from Lån & Spar Bank. However, as breaches of personal data security continue to be reported, where there has been unauthorized disclosure of personal data, the Data Protection Agency recommends that the bank continues to focus on conducting training and awareness activities, etc., and to ensure that procedures, guidelines, workflows, technical security measures, etc., are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Data Protection Agency finally notes that the agency – typically if it receives new reports of breaches of personal data security – may resume the processing of previously reported breaches or include them in the assessment of any future breach or complaint cases.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data. (Data Protection Act)